Payatu Case Study

# Expanding Partnership, A New Model for Continuous Security

Payatu Security Consulting Pvt. Ltd

# Company Profile

The client is a global leader in device security technology, providing trusted solutions that protect mobile devices and enable secure digital services for device manufacturers and financial service providers worldwide. Their technology is embedded in hundreds of millions of devices across the globe, working with leading OEMs and financial institutions.

At the core of their business lies a critical mobile application that enables device financing. The solution tracks monthly EMI (Equated Monthly Installment) payments, and if a payment is missed beyond a configured grace period, the device is locked, protecting lenders from default. The client provides OEM partners with a web portal to manage device lock and unlock operations.

Given the sensitive nature of their technology, directly impacting financial transactions and device security for millions of users, the client recognized the critical need for comprehensive, ongoing security validation of their platform, APIs, and mobile applications.

# Client at a Glance

**INDUSTRY:** Device Security & Mobile Financing Technology

**REACH:** Hundreds of millions devices globally

**PARTNERS:** Leading OEMs (Samsung, Xiaomi, and others)

**CORE PRODUCT:** Device Financing & payment enforcement platform

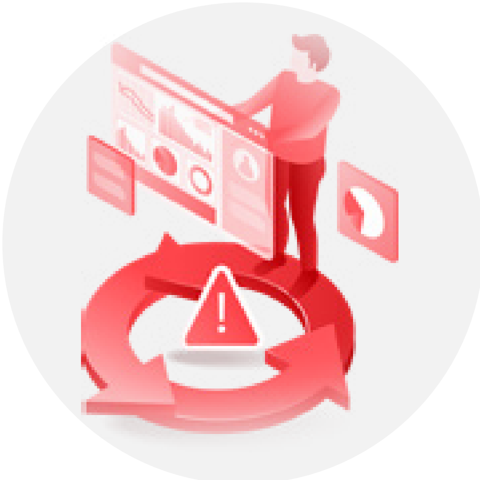
# The Challenge: Outgrowing Project-Based Security

The client's initial engagement with Payatu began as a focused, project-based assessment. Their primary concern was direct:

**Could their device-locking application be bypassed?**

## Critical Finding

Payatu's team successfully bypassed the application - uninstalling the device lock without payment, directly threatening the client's core revenue model. Multiple additional high and critical severity vulnerabilities were also identified.



This initial success led to multiple follow-up engagements as the client recognized the depth of Payatu's expertise. However, as the security needs grew, the traditional project-based model began to show its limitations:

### 1. Repeated Procurement Overhead

Every new assessment required fresh scope definition, effort estimation, commercial negotiations, and agreement signing, creating significant delays.

### 2. Diverse Security Needs

The client needed expertise across mobile application security, cloud infrastructure, network security, architecture review, and threat modeling, requiring different specialists each time.

### 3. Lack of Continuity

With project-based engagements, context was lost between assessments. Each new team had to re-learn the client's architecture and business logic.

### 4. Scaling Difficulty

As the client expanded partnerships with more OEMs, security testing needs grew rapidly, but the engagement model couldn't keep pace.

For a client whose priorities could shift month to month, this overhead was slowing things down at exactly the moment speed mattered most.

# The Solution: Stream-Based Engagement Model

Payatu recognized that the traditional project-based approach, while effective for targeted assessments, wasn't built for this reality.

Rather than fitting the client into an existing engagement template, Payatu designed a model around how this client actually needed to consume security services: continuously, flexibly, and without the procurement friction that comes with re-engaging from scratch every time.

The result was the Stream-based Engagement Model, a fundamentally different approach built to deliver ongoing, multi-domain security coverage under a single, predictable engagement.

# How It Works

### 1. Fixed Monthly Fee

The client pays a predictable fixed monthly cost, eliminating the need for repeated commercial negotiations and enabling better budget planning.

### 2. One Dedicated Security Resource

A skilled security consultant is deployed full-time, aligned to the client's priorities and project requirements throughout the engagement.

### 3. Skill-Based Rotation

Consultants with specific expertise (Application, Cloud, Network, etc.) can be deployed and rotated based on evolving project needs, ensuring the right skill is always available.

### 4. Dedicated Project Manager

A single point of contact ensures continuity, context retention, and smooth coordination across all security initiatives.

### 5. Rolling Engagement

The model operates on a continuous basis throughout the year, focusing on one initiative at a time and seamlessly transitioning between projects.

# Key Advantages

### Faster Turnaround

Eliminates repeated scope definition, effort estimation, and commercial discussions for each new task. The planning is done beforehand, and resources are deployed immediately.

### Cost Efficiency

Instead of engaging multiple vendors or running separate procurement cycles for each security need, the client gets comprehensive coverage under a single, predictable monthly cost.

### Multi-Domain Coverage

A single engagement covers web application testing, mobile application security, cloud security assessment, network penetration testing, threat modeling, and architecture review.

### Context Retention

The dedicated project manager retains institutional knowledge across engagements, ensuring no context is lost when transitioning between different security initiatives.

### Zero Procurement Friction

No repeated SOW signing, no fresh agreements for each engagement. The client simply communicates their priority, and Payatu deploys the right resource.

# Services Delivered Under This Engagement

Through the stream-based model, Payatu has provided the client with comprehensive security coverage across their entire technology stack:

**Mobile Application Security Testing:**
Deep assessment of the core device-financing application, testing bypass scenarios for the payment enforcement mechanism, lock/unlock functionality, and OEM portal integrations.

**Web Application Penetration Testing:**
Comprehensive security assessment of the client's web-based management portal used by OEM partners to manage device operations.

**Cloud Infrastructure Assessment:**
Evaluation of cloud environments hosting the client's platform, identifying misconfigurations, access control weaknesses, and data exposure risks.

**Network Penetration Testing:**
Testing of the client's network infrastructure to identify vulnerabilities in segmentation, access controls, and exposed services.

**Architecture Review:**

Security architecture review of the overall platform design, API integrations, and data flow between OEMs, financial partners, and end-user devices.

**Threat Modeling:**

Systematic identification of potential threats to the client's device financing ecosystem, enabling proactive security measures.

**OSINT:**

Gathering and analyzing information of the devices through social media/public platforms about active breaches.

# Business Impact

During the initial and subsequent engagements, Payatu uncovered critical vulnerabilities that had direct implications on the client's core business model and revenue. The client was able to avoid a greater business impact in terms of -

## 1. Device Payment Bypass at Scale

The bypass vulnerability could have allowed users to unlock financed devices without payment. Across hundreds of millions of devices, even a small exploitation rate would mean massive revenue loss for lenders and a fundamental breakdown of the client's value proposition.

## 2. OEM Partner Attrition

A publicly known exploit in the lock mechanism could trigger OEM partners to re-evaluate or exit their relationship with the client. In a business built entirely on partnerships, losing even one major OEM would have significant commercial consequences.

## 3. Unauthorized Device Operations

Vulnerabilities in the OEM portal and APIs could have enabled unauthorized lock/unlock actions at scale, causing operational chaos for partners and direct financial harm to lending institutions.

## 4. Regulatory and Compliance Exposure

Security gaps in API integrations and access controls risked data exposure across multiple geographies, potentially triggering penalties under GDPR, PCI DSS, and local financial regulations.

## 5. Reputational Damage

In a trust-dependent market, a single public breach would not only impact existing partnerships but hand competitors a powerful argument against the client's platform, making future business development significantly harder.

# Project-Based vs. Stream-Based: At a Glance

| ASPECT | PROJECT-BASED ENGAGEMENT | DEDICATED SECURITY RETAINER |
|---|---|---|
| Engagement Model | Project-based, ad-hoc assessments | Continuous retainer with fixed monthly fee |
| Procurement | New SOW and agreement for each project | Single agreement, rolling engagement |
| Resource Allocation | Dedicated team assembled per project basis | Rotating resource with PM continuity |
| Turnaround Time | Requires scoping and commercial cycle before each project | Immediate deployment on priority change |
| Coverage | Single-domain per engagement | Multi-domain: Mobile, Web, Cloud, Network |
| Cost Model | Per-project pricing based on scope and effort | Fixed monthly fee, predictable budgeting |
| Relationship | Vendor-client transactional | Strategic security partner |

# The Partnership Today

What started as a single question, "Can our app be bypassed?", has grown into a strategic security partnership that continues to this day.

The client, having experienced the flexibility and depth of Payatu's Stream-based Engagement Model, has committed to an ongoing, full-time security engagement.

The engagement has expanded well beyond the initial mobile application bypass testing. The client now relies on Payatu for comprehensive security guidance, including architecture reviews, security best practice recommendations, and continuous assessment of their evolving platform as they onboard new OEM partners and expand into new markets.

# Significant Outcomes

**From Ad-Hoc to Strategic:** Transformed from transactional, one-off testing to a continuous security partnership with full visibility into the client's security posture.

**From Single Domain to Multi-Domain:** Expanded coverage from mobile app testing alone to encompassing web, cloud, network, architecture review, and threat modeling.

**From Reactive to Proactive:** Shifted the client's security approach from finding issues after deployment to identifying and preventing security gaps during the design and development phase.

**Recurring Long-Term Engagement:** The stream-based model has proven its value, the client continues the engagement on an ongoing basis, treating Payatu as an extension of their internal security function.

# About Payatu

Payatu is a Research-powered cybersecurity services and training company specialized in IoT, Embedded Web, Mobile, Cloud, & Infrastructure security assessments with a proven track record of securing software, hardware and infrastructure for customers across 20+ countries.

### Mobile Security Testing

Detect complex vulnerabilities & security loopholes. Guard your mobile application and user's data against cyberattacks, by having Payatu test the security of your mobile application.

### Web Security Testing

Internet attackers are everywhere. Sometimes they are evident. Many times, they are undetectable. Their motive is to attack web applications every day, stealing personal information and user data. With Payatu, you can spot complex vulnerabilities that are easy to miss and guard your website and user's data against cyberattacks.

### Product Security

Save time while still delivering a secure end-product with Payatu. Make sure that each component maintains a uniform level of security so that all the components "fit" together in your mega-product.

### IoT Security Testing

IoT product security assessment is a complete security audit of embedded systems, network services, applications and firmware. Payatu uses its expertise in this domain to detect complex vulnerabilities & security loopholes to guard your IoT products against cyberattacks.

### Security Operations Center

Cyber threats are everywhere, often operating in the shadows. Their goal: to breach networks, compromise systems, and steal critical data. With Payatu's SOC service, you can uncover these hidden threats, bolster your defenses, and protect your data from relentless cyber attacks.

Payatu

## AI / ML Security Audit

Incorrectly implemented AI/ML systems can lead to security and privacy issues. The severity of which depends on how critical the use case is. The repercussions of the same include misclassification of unauthorized entities, theft of intellectual property such as application train models, etc. With a dedicated team capable of effectively assessing and strengthening AI/ML systems, we can provide specific methods to prevent potentially damaging threats before they potentially derail your project.

## Cloud Security Assessment

As long as cloud servers live on, the need to protect them will not diminish. Both cloud providers and users have a shared. As long as cloud servers live on, the need to protect them will not diminish.
Both cloud providers and users have a shared responsibility to secure the information stored in their cloud Payatu's expertise in cloud protection helps you with the same. Its layered security review enables you to mitigate this by building scalable and secure applications & identifying potential vulnerabilities in your cloud environment.

## Code Review

Payatu's Secure Code Review includes inspecting, scanning and evaluating source code for defects and weaknesses. It includes the best secure coding practices that apply security consideration and defend the software from attacks.

## Red Team Assessment

Red Team Assessment is a goal-directed, multidimensional & malicious threat emulation. Payatu uses offensive tactics, techniques, and procedures to access an organization's crown jewels and test its readiness to detect and withstand a targeted attack.

## DevSecOps Consulting

DevSecOps is DevOps done the right way. With security compromises and data breaches happening left, right & center, making security an integral part of the development workflow is more important than ever. With Payatu, you get an insight to security measures that can be taken in integration with the CI/CD pipeline to increase the visibility of security threats.

## Critical Infrastructure Assessment

There are various security threats focusing on Critical Infrastructures like Oil and Gas, Chemical Plants, Pharmaceuticals, Electrical Grids, Manufacturing Plants, Transportation systems etc. and can significantly impact your production operations. With Payatu's OT security expertise you can get a thorough ICS Maturity, Risk and Compliance Assessment done to protect your critical infrastructure.

## CTI

The area of expertise in the wide arena of cybersecurity that is focused on collecting and analyzing the existing and potential threats is known as Cyber Threat Intelligence or CTI. Clients can benefit from Payatu's CTI by getting – social media monitoring, repository monitoring, darkweb monitoring, mobile app monitoring, domain monitoring, and document sharing platform monitoring done for their brand.

## More Services Offered

- Trainings

## More Products Offered

- EXPLIoT


**Payatu Security Consulting Pvt. Ltd.**

www.payatu.com

info@payatu.io

+91-20-47248026